

AGRIAI 2.0 | FORENSIC SOFTWARE EXAMINATION

API Contracts and Reliability

All routes, validation rules, status codes, authentication and response forms

Volume 03

Prepared and authored solely by Thaddeus Nii Teiko Tagoe

Founder, designer and sole creator of AgriAI

Computer Science, University of Ghana

Repository examined: ThaddeusHackz/agriai-v2

Evidence commit: 991457272b7fec548e02c645c5593b930af5ea29

Examination date: 18 August 2026

Classification: Internal technical record

Technical basis

This document is grounded in direct source review, route enumeration, dependency audit, secret pattern scanning, strict TypeScript checking, ESLint, production compilation, PostgreSQL integration tests and local HTTP behavior tests. Live third party AI accounts were not available in the examination environment, so provider success is assessed from code paths and contracts rather than a claim of live production availability.

1. API implementation rule

The backend consists entirely of App Router route handlers. There is no generated OpenAPI file, controller framework or shared schema validator. Every route parses and validates its own payload. Public AI and weather routes try to return a usable degraded response. Admin routes call getSessionUser and return JSON errors when the session is absent.

2. Public and mixed-access route matrix

Method	Path	Access	Input	Output	Important validation
POST	/api/chat	Public	JSON	SSE delta and done	2,000 char message, modes, language, history
POST	/api/vision	Public	JSON base64 image	Disease JSON	100 to 4.5M image string chars
POST	/api/generate	Public	JSON prompt	Image data URL JSON	500 chars and SAFE_SUBJECTS
POST	/api/transcribe	Public	multipart audio	Text JSON	File required, max 25 MB
POST	/api/tts	Public	JSON	audio/mpeg	Text max 1,500, speed 0.5 to 2
POST	/api/search	Public	JSON	Search JSON	Query max 300
GET	/api/weather	Public	city query	Forecast JSON	Five known cities, unknown becomes Accra
GET	/api/prices	Public	live query	Price JSON	live=1 invokes search
POST, DELETE	/api/prices	Session	JSON or id query	Mutation JSON	Any authenticated role
GET, POST, DELETE	/api/history	Public	sessionId and chat	Chat or mutation JSON	No ownership proof
GET	/api/config	Public	None	Public settings JSON	Also returns provider configured flags
GET	/api/health	Public	None	Provider status JSON	Can call Gemini
GET	/api/images	Public	query and count	Unsplash result JSON	Query 100, count max 12
POST	/api/feedback	Public	JSON	Mutation JSON	value up or down
POST	/api/subscribe	Public	JSON	Mutation JSON	Basic email check
POST	/api/contact	Public	JSON	Mutation JSON	Name, email, message required
POST	/api/track	Public	JSON	Always ok JSON	visitorId max 64

3. Admin route matrix

Method	Path	Access	Function
POST	/api/admin/login	Public	Credentials to cookie session
POST	/api/admin/logout	Cookie optional	Delete server session and clear cookie
GET	/api/admin/me	Session	Return public user fields
GET	/api/admin/analytics	Session	Aggregate dashboard metrics
GET, DELETE	/api/admin/feedback	Session	List or delete feedback
GET, POST, DELETE	/api/admin/knowledge	Session	Knowledge CRUD, no separate editor policy
GET, DELETE	/api/admin/messages	Session	Read or delete chat records
POST	/api/admin/reset	Admin role	Reset the full database after RESET confirmation
GET, POST	/api/admin/settings	Session	Read or patch settings, force PostgreSQL sync
GET, DELETE	/api/admin/subscribers	Session	List, CSV export or delete
GET, POST, PATCH, DELETE	/api/admin/users	Admin role	User lifecycle and password reset

4. Chat request contract

```
POST /api/chat
Content-Type: application/json
{
  "message": "required text, trimmed and capped to 2000",
  "language": "en | tw | ga | ee | ha | fr",
  "mode": "standard | expert | agent",
  "webSearch": true,
  "history": [{"role": "user|assistant", "content": "..."}],
  "sessionId": "browser identifier, first 64 chars"
}
```

Invalid JSON returns 400 Invalid JSON body. Empty message returns 400 Message is required. Valid requests return HTTP 200 and an SSE stream, even when all remote AI services are unavailable. Provider is gemini, cloudflare or local. demo is true only for the local answer path. Search sources are removed if the route falls all the way to localAnswer.

5. Chat reliability semantics

- * The route performs search before opening the output stream. A slow search delays the first byte.
- * Gemini deltas are emitted during generation. A model failure clears server fullText and starts the next provider.
- * Cloudflare returns a complete response, so no delta frames are emitted for that tier.
- * localAnswer always produces non-empty text from knowledge, curated patterns or a generic card.
- * Conversation persistence happens before done. persist() catches disk errors, so the answer can still complete even if storage fails.
- * The client AbortController passes request.signal to Gemini and Cloudflare, but the ReadableStream cancel callback has no additional cleanup.

6. Vision contract

```
POST /api/vision
{"image":"data:image/jpeg;base64,...", "language":"en"}

200:
{
  "detected":"condition name",
  "confidence":0,
  "description":"text",
  "treatment":["step"],
  "demo":false
}
```

The route returns 400 for a short or non-string image, 413 above the character cap, 500 for unexpected route failure and 200 with demo:true when Gemini is missing or every model fails. The server does not verify decoded bytes, image dimensions or a magic signature.

7. Generate contract

POST /api/generate returns 503 before parsing the body when neither Cloudflare nor Gemini is configured. Invalid JSON returns 400. Empty or non-agricultural prompts return 400. Successful output contains ok:true, image and provider. Failure after configured provider attempts returns 502. The content gate is a substring list and not a complete safety policy.

8. Voice contracts

Route	Success	Expected failures	Operational note
POST /api/transcribe	200 {text}	400 no file, 413 above 25 MB, 501 no Gemini, 500 model failure	Entire audio buffered and base64 encoded
POST /api/tts	200 audio/mpeg	400 no text, 501 no ElevenLabs, 502 vendor error, 500 route error	Response says public max-age=3600

9. Weather contract

GET /api/weather accepts a city name. The map recognizes Accra, Kumasi, Tamale, Takoradi and Cape Coast. Unknown input silently becomes Accra. OpenWeather success returns source openweather and demo:false. Open-Meteo returns source open-meteo and demo:true. Seeded fallback returns source seed and demo:true. Current contains temp, humidity, precip and wind. Daily contains five rows with date, tmax, tmin, precip and wind.

10. Price contract

GET /api/prices is public and can invoke live search with live=1. POST and DELETE are in the same route file but require any valid admin or editor session. POST accepts crop, market, numeric price and unit; date, trend and note are optional. If body.id matches an existing row, the route updates it. The API accepts negative and extremely large numbers because no economic range is checked.

11. Configuration exposure

GET /api/config deliberately returns only selected site settings, but also returns providerStatus booleans and the configured model name. It does not return the secret values. GET /api/health goes further by attempting a Gemini generation and returning a trimmed raw exception message on failure. That route creates an avoidable quota and information-disclosure surface.

12. Admin session contract

```
POST /api/admin/login
{"email":"...", "password":"...", "remember":true}

Set-Cookie: agriai_session=<64 hex chars>
  HttpOnly
  SameSite=Lax
  Secure only in production
  Path=/
  Max-Age=7 days when remember, otherwise 8 hours
```

The server session always expires seven days after creation, even when the browser cookie uses eight hours. The token is 32 random bytes encoded as 64 hex characters and is stored in the Database.sessions array. It is an opaque reference, not a signed claim. Login allows five recorded failures in 15 minutes per in-memory IP key.

13. Error response philosophy

Most routes return JSON {error:string} for validation and upstream failure. Chat differs because its success envelope is SSE. Track intentionally returns {ok:true} even on malformed input. Search catches provider failure and returns keyless results. Weather logs errors and descends its provider chain. Database write failures are logged and swallowed by persist(). This keeps the UI alive but can conceal data loss unless logs and alerts are watched.

14. Reliability is not perfection

Engineering interpretation

The API feels reliable because fallback payload shapes are stable. Reliability does not establish agronomic correctness, provider freshness, durability under concurrent instances or safety under hostile traffic. Those properties require quotas, schemas, monitoring, tests and evidence beyond graceful catch blocks.

Authorship and control statement

This volume was prepared, authored and issued solely under the name of Thaddeus Nii Teiko Tagoe. This route inventory and contract analysis is the reference for anyone implementing an AgriAI client or reviewing backend behavior. The repository records identify Thaddeus Tagoe as the founder, sole designer, developer and maintainer of AgriAI.